

PCC190: Secure Machine Learning

Exam 1

Name: _____

Date: _____

Student ID: _____

Duration: 100 minutes

Instructions. Every question presents a scenario and asks you to reason about it. Nothing here is graded on reciting definitions. Names of categories (for example, the labels of a taxonomy) may be replaced by a correct description in your own words, and a correct name with a justification that does not fit the scenario earns little credit. Answer in a few lines per item and state your assumptions when a scenario is underspecified. Each question is worth 20 points, so plan for about 18 minutes per question. Feel free to ask me anything during the exam. If your question is not about the content being evaluated, I will be glad to answer it.

Notation. Data live in $\mathcal{Z} = \mathcal{X} \times \mathcal{Y}$ with distribution P_Z . A learner $H^{(N)}$ maps a training set $D^{(train)}$ of N examples to a hypothesis $f \in \mathcal{F}$. The loss is $\ell(y, \hat{y}) \geq 0$, the risk is $R(P_Z, f) = \mathbb{E}_{(x,y) \sim P_Z}[\ell(y, f(x))]$, and the empirical risk on a dataset D is $\tilde{R}_N(f) = \frac{1}{N} \sum_{(x,y) \in D} \ell(y, f(x))$. In binary security tasks the positive class (+) is malicious and the negative class (−) is benign. A false positive (FP) is a benign instance labeled +; a false negative (FN) is a malicious instance labeled −. FPR is the fraction of benign instances flagged and FNR the fraction of malicious instances missed. In attack scenarios, $A^{(train)}$ and $A^{(eval)}$ denote the attacker's procedures that shape the training and the evaluation data, respectively.

Question	1	2	3	4	5	Total
Points	20	20	20	20	20	100
Score						

Question 1: A learned phishing filter for a university

[20 points]

A university with 30,000 mail accounts filters phishing¹ with rules written and updated by its security analysts. The IT director proposes replacing the rules with a classifier retrained every night. Features come from message content and sender metadata. Labels come from the "Report phishing" and "Not phishing" buttons, which any user can click on any message. The proposal states: "Because the model adapts to new campaigns, attackers will find it harder to evade than a fixed rule set."

- (a) [10] (i) Give two properties of this task that make a learning-based approach attractive. (ii) Explain in what sense the proposal's claim is only half right: which property of the learner produces the benefit, and why does the same property create an attack surface that the rule set does not have? (iii) Name the assumption about the data on which most learning guarantees rely. Describe one concrete way an adversary could violate it through the *training* data and one through the *evaluation* data in this deployment.
- (b) [10] Two statements from the project meeting: (i) "No attacks on the current filter have been reported, so we will run the security review after launch." (ii) "The feature list and model type are proprietary, so the review can assume the attacker knows neither." Respond to each using the design principles discussed in Chapter 1. Then state, in one sentence, a more defensible assumption about attacker knowledge for (ii).

Question 2: Statistical learning applied to a security task

[20 points]

A network intrusion detector is a binary classifier with $\mathcal{X} = \mathbb{R}^D$ and $\mathcal{Y} = \{-, +\}$.

- (a) [6] A learner $H^{(N)}$ returns the hypothesis f defined as follows: if the input appears in $D^{(train)}$, return its training label; for every other input, return −. Assume 5% of sessions in P_Z are malicious, the features are real-valued so that a new session never repeats a training point, and the loss is 0 for a correct prediction, 10 for an FN and 1 for an FP. (i) Compute $\tilde{R}_N(f)$ on $D^{(train)}$. (ii) Compute $R(P_Z, f)$. (iii) Name the phenomenon and give two different ways to prevent it, saying which object of the learning setup each one changes.

¹A social engineering attack in which someone impersonates a trusted party, such as a bank, an employer, a delivery company or a university IT office, to trick you into handing over sensitive information or taking a harmful action.

- (b) [9] Two classifiers are evaluated on the same $D^{(eval)}$ of 1000 sessions, of which 40 are malicious. Classifier A makes 8 FNs and 48 FPs. Classifier B makes 2 FNs and 120 FPs. Let the loss be c for an FN and 1 for an FP. (i) Give FPR and FNR of each. (ii) Give the empirical risk of each as a function of c . (iii) For which values of c is B preferable? (iv) In one sentence each, describe a deployment where a large c is justified and one where a small c is.
- (c) [5] Assign each attack to the phase of the learning pipeline it targets (measurement, feature selection, learning model, training, prediction). (i) Padding phishing pages with innocuous content so that extracted measurements look like those of benign pages. (ii) Injecting data so that a feature selection step, which ranks features using the training set, promotes a useless feature. (iii) Building instances that no linear boundary can separate against a learner that assumes linear separability. (iv) Repeatedly querying the deployed classifier to find instances it misses. Then state which phase is the costliest to repair after a successful attack and why.

Question 3: Security goals

[20 points]

Consider four systems and adversaries.

- A. An endpoint classifier labels executables as malware on a company's laptops. A ransomware crew wants its sample to run.
- B. A payments processor's fraud model automatically blocks suspicious transactions. A rival wants a competitor's legitimate transactions to be blocked.
- C. A hospital publishes a readmission-risk model as a public web calculator. An insurer wants to learn whether a specific applicant's record was used to train it. It only sends queries and reads the returned scores.
- D. A spam filter is retrained on user feedback. A spammer sends messages designed so that, after retraining, legitimate messages from one bank are filtered as spam. Every message the spammer sends is genuinely spam.
- (a) [12] For each system, state the asset at stake, the security goal being attacked, and the error type (FN, FP, or neither) that the attack needs to induce or exploit. In addition, for C explain why the FN and FP rates of the model cannot reveal this breach and why some leakage is unavoidable, and for D explain the apparent mismatch between the kind of messages the attacker sends and the kind of failure it wants.
- (b) [8] For the endpoint classifier of A, the evaluation set has 1000 files, 50 malicious and 950 benign. Before an attack targeting one malware family, the classifier makes 5 FNs and 22 FPs. Afterwards it makes 25 FNs and 22 FPs. (i) Compute accuracy and FNR before and after. (ii) A manager concludes "accuracy fell by only two points, no incident." Explain why this is wrong and which measurements should be reported for a security-sensitive detector.

Question 4: Building threat models

[20 points]

System 1. A backbone operator, every 5 minutes, collects the byte counts on all links into one vector and fits PCA on the last weeks of vectors to model normal traffic. It raises an alarm when a new vector is far from the normal subspace. The adversary is a botnet operator planning a volume-based denial-of-service attack against a customer and wants it to go unnoticed. The adversary can send traffic through the backbone from many hosts but does not control other users' traffic or the routing.

System 2. A spam filter retrained periodically on user feedback, targeted by a spammer.

- (a) [8] For System 1: (i) Should the corruption be modeled as data insertion or data alteration? Justify with how data points are generated. (ii) Which class of instances can the adversary influence, and what is peculiar about this detector's training data? (iii) Are all features equally controllable? Give a concrete example.
- (b) [5] For System 2, write a compact threat model of the spammer covering its *incentives, objectives, resources, capabilities and knowledge*, and *limitations*. Each element must be specific to this system and stated in one sentence.
- (c) [7] Two analysts disagree. Analyst A: "assume the attacker controls 100% of the training data and knows everything." Analyst B: "assume the attacker can inject at most 1% of messages, cannot choose labels

and knows nothing about the system.” Critique each in one or two sentences, and state what the security report should deliver instead.

Question 5: Taxonomy and the adversarial learning game**[20 points]**

- (a) **[8]** Classify each scenario along the three axes of the taxonomy of attacks (influence, security violation, specificity), with a one-line justification tied to the scenario.
- S1.** A spam filter is retrained on user feedback. A spammer wants one particular message, a competitor’s tender reply expected tomorrow, to be filtered, and sends correctly labeled spam containing words it expects in that reply.
 - S2.** A botnet operator adds chaff traffic over several weeks to the training window of a PCA-based volume detector, so that later denial-of-service attacks on any link will not raise alarms.
 - S3.** An insurer queries a public medical risk model to determine whether one applicant’s record was in the training set.
 - S4.** An intrusion detection system is deployed and frozen (no retraining). An attacker forges packets carrying a competitor’s web store as source so that the system blocks the store’s real customers.
- (b) **[6]** A malware author has black-box access to an antivirus vendor’s cloud API. The author submits variants of one sample and observes the verdicts until a variant passes, then deploys that variant. (i) Classify influence and violation. (ii) Is the attack Targeted or Indiscriminate? Explain what the answer depends on. (iii) Suppose the vendor adds submitted samples to its next retraining set. What changes in the classification, which attacker procedure ($A^{(train)}$ or $A^{(eval)}$) is now available, and why does it matter for the defender?
- (c) **[6]** Three candidate defenses: (D1) sanitize the training set by discarding points whose inclusion increases error on trusted data; (D2) monitor and rate-limit queries to the deployed model; (D3) add calibrated noise to the trained model before release (differential privacy). For each, name the part of the taxonomy it addresses and one part it leaves uncovered. Then state one cost that all three defenses share and explain why a defense for one class of attack does not automatically cover another.